

Project 1: Windows SMB Brute Force Detection (T1110)

1. Overview

This project focuses on engineering custom detections for network-based brute-force attacks. As default SIEM rules often generate extreme alert fatigue by alerting on every single failed login, the objective of this lab was to simulate a targeted SMB brute-force attack, analyze the resulting Windows Security log telemetry, and engineer state-tracking correlation rules. By utilizing Wazuh and Sysmon, I developed both a Wazuh XML rule and a vendor-neutral Sigma rule that detect the specific behavior of a brute-force attack (frequency and threshold) rather than isolated incidents.

2. Lab Architecture

The environment was constructed entirely within Oracle VirtualBox on an isolated Host-Only network (`192.168.56.x`) to ensure safe malware and attack simulation.

- **SIEM Manager:** Wazuh Manager running on Ubuntu Linux.
- **Target Endpoint:** Windows 11 Enterprise (IP: `192.168.56.101`). This machine was configured with Sysmon and the Wazuh Agent to forward detailed security telemetry to the manager.

- **Attack System:** Kali Linux (Hostname: `Ellzy`, IP: `192.168.56.103`) equipped with penetration testing tools like Hydra and NetExec.

3. The Technique

- **MITRE ATT&CK ID:** T1110.001 - Brute Force: Password Guessing
- **Description:** Threat actors systematically guess passwords to gain access to valid accounts. In a corporate environment, Server Message Block (SMB) on port 445 is a prime target because it is frequently exposed internally for file sharing and active directory authentication.

4. Attack Simulation

Before executing the attack, several modern Windows 11 default defenses had to be disabled to simulate a vulnerable legacy server and ensure the OS would process a continuous stream of authentication attempts.

Step 1: Bypassing Windows 24H2 Defenses By default, Windows 11 24H2 enforces an SMB rate-limiter that intentionally delays failed NTLM authentication attempts by 2 seconds to break brute-force tools. I disabled this via an elevated PowerShell session:

```
Set-SmbServerConfiguration -RequireSecuritySignature $false
Set-SmbServerConfiguration -InvalidAuthenticationDelayTimeInMs 0
```

Step 2: Disabling Account Lockout Policies To ensure the target account (`svc_test_account`) would not lock out after 3 failed attempts (which would stop the OS from generating the required 4625 logs), I set the lockout threshold to zero and unlocked the test account:

```
net accounts /lockoutthreshold:0
Unlock-LocalUser -Name "svc_test_account"
```

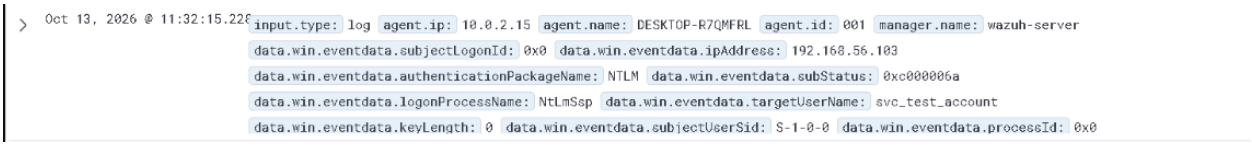
Step 3: Executing the Attack With the target prepped, I launched a targeted SMB brute-force attack from my Kali Linux machine using NetExec (`nxc`). I utilized a

custom password list containing several incorrect passwords, terminating with the correct password to generate a full attack lifecycle.

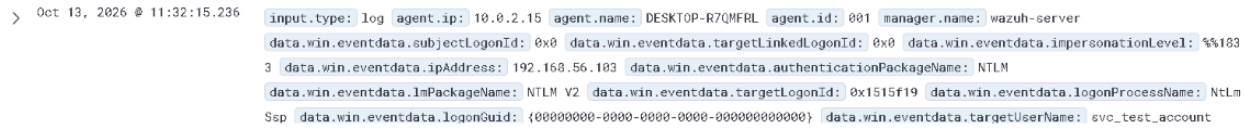
```
nxc smb 192.168.56.101 -u svc_test_account -p passwords.txt --local-auth
```

5. Evidence

The attack successfully generated Event ID 4625 (Failed Logon) logs corresponding to the incorrect passwords in the wordlist, immediately followed by an Event ID 4624 (Successful Logon) when the correct password was executed.



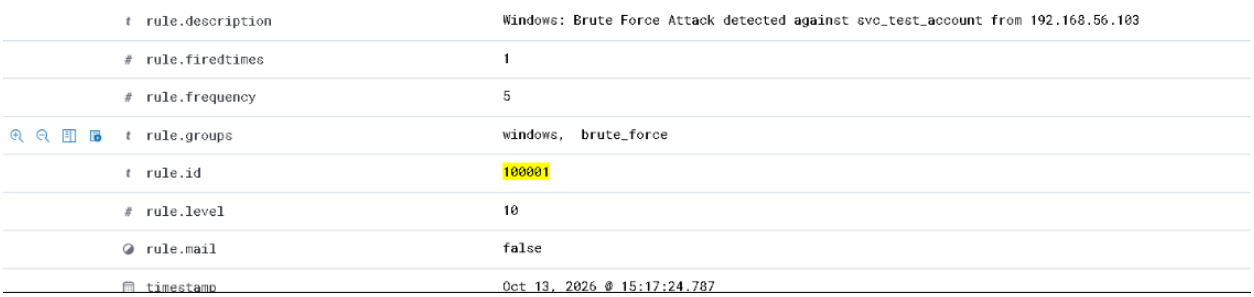
: Event ID 4625 capturing the attacker IP (`192.168.56.103`), the targeted account (`svc_test_account`), and the `0xc000006a` (bad password) subStatus code.*



: Event ID 4624 showing the final successful authentication following the burst of failures.*

6. Detection

To accurately identify this attack without flooding the SOC with false positives, I engineered a custom detection rule that looks for 5 identical failures from the exact same source IP within 60 seconds.<img <img : Wazuh Dashboard confirming the custom correlation rule (Rule ID: 100001) successfully fired in response to the attack simulation.*



t	rule.description	Windows: Brute Force Attack detected against svc_test_account from 192.168.56.103
#	rule.firedtimes	1
#	rule.frequency	5
t	rule.groups	windows, brute_force
t	rule.id	100001
#	rule.level	10
	rule.mail	false
	timestamp	Oct 13, 2026 @ 15:17:24.787

Wazuh XML Correlation Rule (ID: 100001) This rule was configured in `/var/ossec/etc/rules/local_rules.xml` on the Wazuh Manager. It uses a parent-child relationship (`if_matched_sid`), meaning it only evaluates logs that have already triggered the baseline Windows failed login rule (60122).

```
<group name="windows, brute_force,">
  <rule id="100001" level="10" frequency="5" timeframe="60">
    <if_matched_sid>60122</if_matched_sid>
    <same_field>win.eventdata.ipAddress</same_field>
    <description>Windows: Brute Force Attack detected against $(win.eventdata.targetUserN
ame) from $(win.eventdata.ipAddress)</description>
    <mitre>
      <id>T1110</id>
    </mitre>
  </rule>
</group>
```

Vendor-Neutral Sigma Rule Translation To demonstrate vendor-agnostic detection engineering, I translated the logic into a Sigma rule. This ensures the detection can be rapidly compiled into Splunk SPL, KQL (Microsoft Sentinel), or Elastic queries. Notice the specific filtering for `LogonType: 3` (Network) and `10` (RemoteInteractive) to filter out physical keyboard typos.

```
title: Failed Network Logon
name: failed_network_logon
logsource: {product: windows, service: security}
detection:
  selection: {EventID: 4625, LogonType: [3, 10]}
  condition: selection
---
title: Brute Force - 5+ Failed Logons From One Source
correlation:
  type: event_count
  rules: [failed_network_logon]
```

```
  group-by: [IpAddress]
  timespan: 60s
  condition: {gte: 5}
level: high
```

- **Note on Detection Logic:** While the Sigma correlation rule strictly filters for network and RDP logons (LogonType: [3, 10]), the custom Wazuh rule deployed in this lab evaluates all Event ID 4625 occurrences regardless of logon type to maximize visibility across local and network authentication failures.

7. Analyst Triage

Upon receiving this Level 10 alert, a Tier 1 Analyst should:

1. Identify the targeted account (`svc_test_account`) and determine its current privilege level in Active Directory or the local SAM database.
2. Query the SIEM for Event ID 4624 (Successful Logon) originating from the attacker's IP (`192.168.56.103`) immediately following the 4625 alerts to determine if the brute force was successful.
3. If successful authentication occurred, analyze Sysmon telemetry for subsequent processes spawned by that user account to identify potential lateral movement or payload execution.

8. False Positives and Tuning

While this rule correlates frequency to reduce noise, it may still trigger legitimate false positives in a corporate network due to:

- **Expired Service Accounts:** Automated scripts, backups, or scheduled tasks retrying authentication with an outdated cached password.
- **Vulnerability Scanners:** Corporate tools (e.g., Nessus, Qualys) executing authenticated scans with misconfigured or expired credentials.
- **VPN/Wi-Fi Reconnects:** Mobile devices rapidly attempting to reconnect to corporate networks using old credentials after a user changes their password.

9. Response and Mitigation

- **Containment:** If a successful 4624 event is observed, immediately isolate the compromised Windows endpoint from the network to halt lateral movement.
- **Eradication:** Force a password reset for the compromised account (`svc_test_account`) and revoke any active session tokens.
- **Prevention:** Re-enable the account lockout threshold (`net accounts /lockoutthreshold:5`) and ensure strict SMB signing is enforced via Group Policy to mitigate NTLM relay and brute-force efficiency. Block the attacking IP at the perimeter firewall or network switch.

10. Lessons Learned

Relying on single-event alerts is ineffective for modern threat detection. Effective detection engineering requires state-tracking correlation—monitoring frequency, timeframes, and specific fields (like LogonType 3 for network connections versus Type 2 for physical keyboards) to accurately identify malicious intent while minimizing false positives for the SOC.

11. References

- MITRE ATT&CK T1110 - Brute Force
- Microsoft Event ID 4625 Documentation